

WEB APPLICATION VULNERABILITY ASSESSMENT AND PENETRATION TESTING

1



Disclaimer

All information contained in this document is confidential and proprietary to **Vsion Networks** and **XYZ PVT LTD**. Reproduction, disclosure, or use of any information contained in this document by photographic, electronic or any other means, in whole or part, for any reason other than for the purpose of operations and/or security enhancement of **XYZ PVT LTD** through internal review is strictly prohibited without written consent.

The use of the information / test results **XYZ PVT LTD** name responsibility and depends on the **Vsion Networks** ability to evaluate and integrate it into **XYZ PVT LTD** name operational environment. While each item may have been reviewed by **Vsion Networks** for accuracy in a specific situation, there is no guarantee that the same or similar results will be obtained elsewhere.

Neither **Vsion Networks** nor any of its employees makes any warranty, expressed or implied, or assumes any legal liability or responsibility for the completeness or usefulness of any information, report or process disclosed herein or represents that its use will not infringe privately owned rights.

Limitations on Disclosure and Use

This document contains sensitive and confidential information concerning vulnerabilities of **XYZ PVT LTD** name target infrastructure. **Vsion Networks** recommends that special precautions be taken to protect the confidentiality of the information contained in this report.

While **Vsion Networks** is confident that the major security vulnerabilities of the target Infrastructure have been identified, there can be no assurance that an assessment of this nature will identify all possible security exposures. Additionally, the findings and recommendations presented in this document are based on the technologies and known threats as of the date of this report. As technologies and risks change over time, the vulnerabilities and the recommendations associated with the Client Name target infrastructure may also change.

Contents

Executive Summary	5
Assessment Types & Scope	6
Vulnerabilities Table	8
1. Logjam Vulnerability	9
2. Outdated Nginx Version with Known Vulnerabilities	11
3. LUCKY13 Vulnerability	13
4. BEAST Vulnerability	15
5. TLS Version 1.1 Deprecated Protocol	17
6. HSTS Missing from HTTPS Server	20
Attacks and Exploits Performed	22
Appendix A – Vulnerability Severity Rating	25

PROJECT OVERVIEW

Activity



WEB APPLICATION VULNERABILITY ASSESSMENT AND PENETRATION TESTING

Prepared by: Arun Kumar

Reviewed by: Vinoth Kumar V

Start Date: 26-07-2025.

End Date: 31-07-2025.

Test Location: [Remote]

Executive Summary

Vsion Networks conducted the infrastructure vulnerability assessment of **XYZ PVT LTD** accessible over the internet to identify Infrastructure vulnerability assessment from internal environment. The Penetration Testing was performed from 26th July 2025 to 31th July 2025.

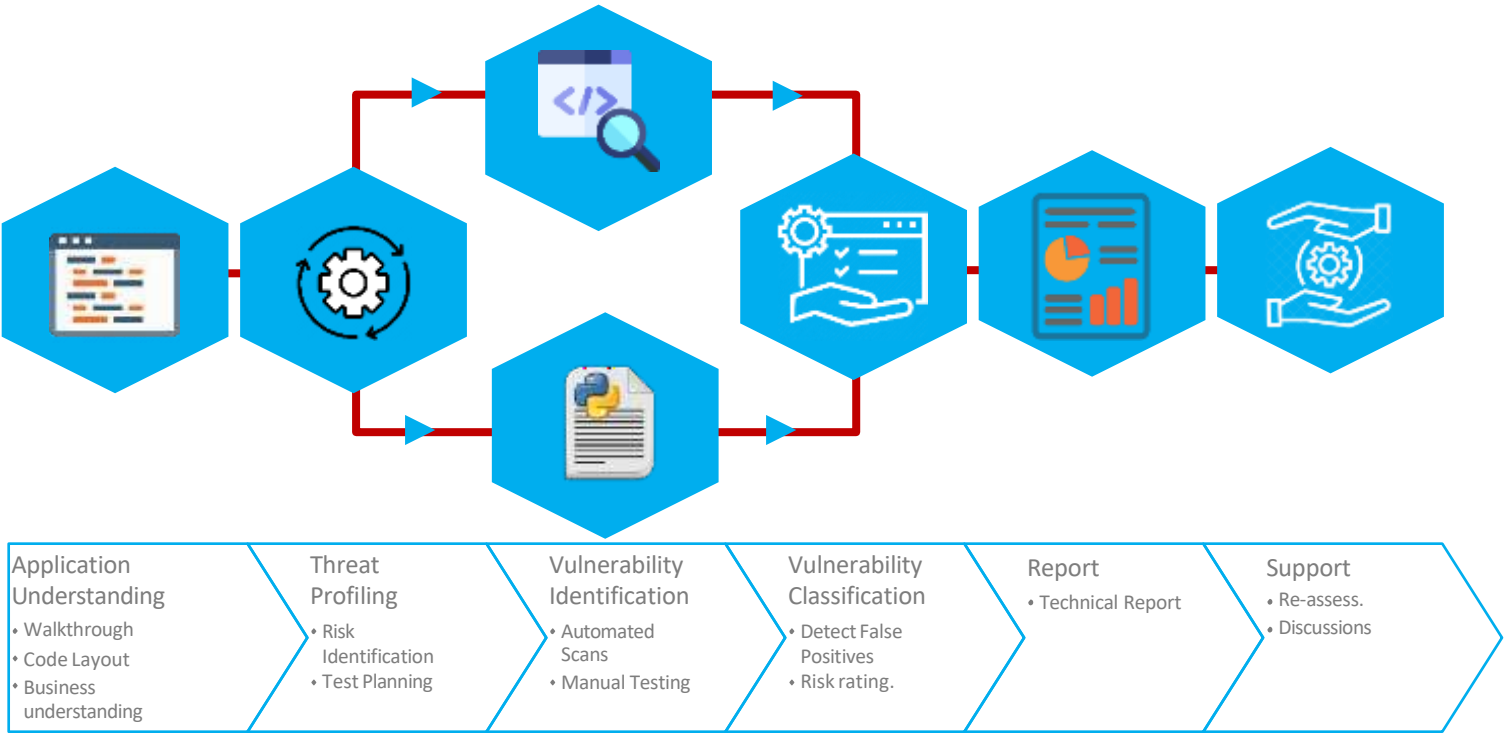
Infrastructure vulnerability assessment was limited to the scope mentioned in the Statement of Work agreed between **Vsion Networks** and **XYZ PVT LTD**

Objective

The objective of this exercise was to assess the **XYZ PVT LTD** infrastructure against unauthorized attacks and detect vulnerabilities that may pose a threat to its systems and the application. The report also aims at providing recommendations and guidelines against such threats, which help in protecting the confidentiality and integrity of its systems and the application. The testing process included the use of automated tools as well as manual tests.

Approach

The testing methodology is a hybrid policy based on OWASP top 10, NIST, OSSTMM standards and is as follows:



Assessment Types & Scope

The type of scan or audit performed determines the nature of the testing conducted on the Web App within the defined scope:

Scan/Audit Type		
Level	Type	Information
1	Standard	In standard penetration testing, denial of service conditions is avoided. Any disruptive scanning is also avoided to ensure that the application retains its state at the end of the assessment. This is recommended on a live environment.
2	Destructive	In a destructive penetration testing, denial of service conditions is exploited. Additionally, any disruptive scanning that may cause environment to go down is exploited in a destructive scan. Such a scenario helps to identify the vulnerabilities that may be used by an attacker to trigger a denial-of-service situation. This is least recommended on a live environment unless there really is a need.

The vulnerabilities discovered are associated with a risk level that indicates how critical the vulnerability is and helps infrastructure team to prioritize the vulnerabilities and choose an appropriate mitigation approach.

Assessment Scope

The infrastructure security assessment is done on but not limited to the following:

- Fingerprinting
- Active Services
- Vulnerability Exploits
- Risk Assessment
- Infrastructure Assessment

Out of Scope:

- Denial of Service by exhausting system resources
- Social Engineering

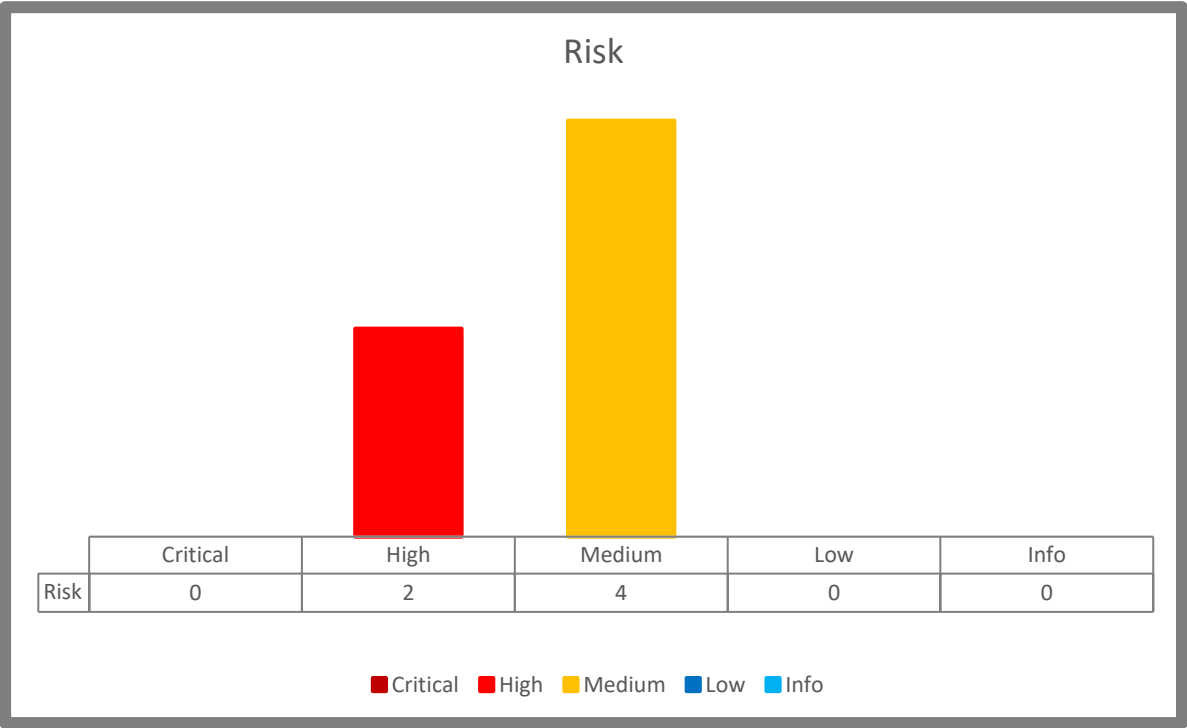
Scan Type:

Assessment type	Selected
Standard	Yes
Destructive	No

Vulnerability Overview

The Mobile Application Vulnerability Assessment in identification of 0 Critical Risk Vulnerabilities, 2 High Risk Vulnerabilities, 4 Medium Risk Vulnerabilities, 0 Low Risk vulnerabilities and 0 Info Risk vulnerabilities.

Outcome Summary



Vulnerabilities Table

Sl. No	Vulnerability Count	Critical	High	Medium	Low	Info	Total
1	Total vulnerabilities Identified	0	2	4	0	0	6

Sl. No	Vulnerability	Risk Rating	CVSS Score	CVE ID
1	Outdated Nginx Version with Known Vulnerabilities	High	7.5	CVE-2018-16843, CVE-2018-16844
2	Logjam Vulnerability	High	7.4	CVE-2015-4000
3	BEAST Vulnerability	Medium	6.8	CVE-2011-3389
4	TLS Version 1.1 Deprecated Protocol	Medium	6.5	N/A
5	HSTS Missing from HTTPS Server	Medium	6.5	N/A
6	LUCKY13 Vulnerability	Medium	5.9	CVE-2013-0169

1. Logjam Vulnerability

High

CVSS Score: 7.4

CVSS Vector: 3.1/ AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

CVE ID: CVE-2015-4000

Description:

The Logjam vulnerability allows a man-in-the-middle attacker to downgrade TLS connections using weak Diffie-Hellman (DH) parameters, especially 512-bit export-grade cryptography, which is considered insecure.

When a server supports these weak DH parameters, attackers can downgrade secure connections and eventually decrypt TLS traffic, violating HTTPS confidentiality.

Solution:

- Upgrade Disable support for export-grade cipher suites (e.g., DHE_EXPORT).
- Use 2048-bit or stronger Diffie-Hellman groups.
- Update your TLS library (OpenSSL) to the latest secure version.
- Regenerate DH parameters using:

Impact:

- Exploit Confidentiality: High — Encrypted communication can be passively decrypted.
- Integrity: None — The vulnerability does not modify data.
- Availability: None — No denial-of-service impact.
- Possible regulatory non-compliance for systems requiring strong encryption (PCI DSS, HIPAA).

Remediation:

- Upgrade Audit all services using TLS (web, mail, VPN).
- Patch OpenSSL and related libraries.
- Disable DHE_EXPORT and weak ciphers.
- Use modern protocols and cipher suites:

Reference:

- <https://nvd.nist.gov/vuln/detail/CVE-2015-4000>
- <https://openssl-library.org/news/secadv/20150611.txt>

Attached POC:

```
(kali@kali)-[~/testssl.sh]
└─$

rDNS (13.127.158.240):  ec2-13-127-158-240.ap-south-1.compute.amazonaws.com.
Service detected:      HTTP
Testing for LOGJAM vulnerability
LOGJAM (CVE-2015-4000), experimental  VULNERABLE (NOT OK): common prime: nginx/1024-bit MODP group with safe prime modulus (1024 bits),
but no DH EXPORT ciphers
```

2. Outdated Nginx Version with Known Vulnerabilities

High

CVSS Score: 7.5

CVSS Vector: 3.1/ AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

CVE ID: CVE-2018-16843, CVE-2018-16844, CVE-2019-20372, CVE-2021-23017, CVE-2017-7529

Description:

The target server is running Nginx version 1.10.3, released in 2016, which is affected by multiple high and medium severity vulnerabilities. This version has not received security updates for several years and remains susceptible to DoS attacks, memory corruption, and HTTP/2-specific vulnerabilities.

These issues may be remotely exploitable and could lead to denial-of-service, memory leakage, or in some cases even code execution depending on the module configuration.

Solution:

Upgrade to the latest stable Nginx version, such as:

- 1.24.x (Stable) or mainline: 1.25.x

Always monitor the [Nginx Security Advisories](https://nginx.org/en/security_advisories.html)

Impact:

- Denial-of-Service (DoS) via malformed or malicious HTTP/2 traffic.
- Information leakage or memory corruption in older Nginx modules.
- Exploitable vulnerabilities in public CVE databases.

Remediation:

- Backup your current configuration.
- Update Nginx via your package manager:
 - bash
 - sudo apt update
 - sudo apt install nginx
- Alternatively, build from source for custom versions.
- Restart the service and verify:
 - bash
 - nginx -v

Reference:

- <https://nvd.nist.gov/vuln/detail/CVE-2018-16843>
- <https://nvd.nist.gov/vuln/detail/CVE-2017-7529>
- https://nginx.org/en/security_advisories.html

Attached POC:

```
HTTP/1.1 200 OK
Server: nginx/1.10.3 (Ubuntu)
Date: Tue, 29 Jul 2025 05:31:27 GMT
Content-Type: text/html
Content-Length: 851
Last-Modified: Mon, 07 Jul 2025 16:02:46 GMT
Connection: keep-alive
ETag: "686befa6-353"
Accept-Ranges: bytes
```

3. LUCKY13 Vulnerability

Medium

CVSS Score: 5.9

CVSS Vector: 3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

CVE ID: CVE-2013-0169

Description:

LUCKY13 is a timing side-channel attack against implementations of the TLS/DTLS protocol using CBC (Cipher Block Chaining) mode encryption.

It allows a remote attacker to recover plaintext from encrypted TLS messages by carefully measuring the time it takes a server to process malformed TLS records.

Affected components include:

- OpenSSL
- GnuTLS
- PolarSSL
- Other TLS stacks implementing CBC-mode ciphers with improper timing countermeasures.

Solution:

- Update TLS libraries (OpenSSL, GnuTLS, etc.) to patched versions that introduce constant-time decryption.
- Disable CBC-mode cipher suites and prefer modern, AEAD-based ciphers like AES-GCM or ChaCha20-Poly1305.
- Prefer using TLS 1.2+ with AEAD ciphers, or TLS 1.3, which is not vulnerable.
- Configure
 - SSLCipherSuite ECDH+AESGCM: EDH+AESGCM
 - SSLProtocol all -SSLv2 -SSLv3 -TLSv1 -TLSv1.1.

Impact:

- Disclosure Confidentiality: High — Leaks parts of the encrypted data (e.g., session cookies).
- Integrity: None
- Availability: None
- Although the attack requires high precision and is difficult to pull off reliably, it remains a cryptographic weakness in outdated systems.

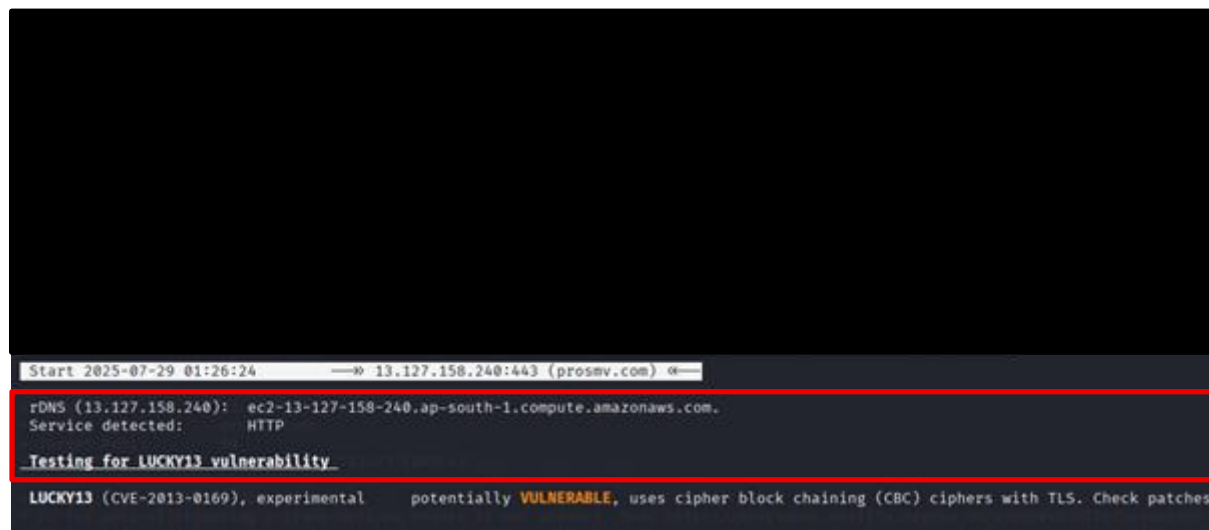
Remediation:

- Upgrade to the latest versions of OpenSSL or TLS libraries.
- Disable CBC-mode ciphers and SSL/TLS protocol versions prior to 1.2.
- Configure web and application servers to enforce strong TLS configurations.
- Prefer AEAD ciphers (e.g., AES-GCM or ChaCha20-Poly1305).

Reference:

- <https://nvd.nist.gov/vuln/detail/CVE-2013-0169>
- <https://www.isg.rhul.ac.uk/tls/Lucky13.html>

Attached POC:



```
Start 2025-07-29 01:26:24 --> 13.127.158.240:443 (prosmv.com) <-->
rDNS (13.127.158.240): ec2-13-127-158-240.ap-south-1.compute.amazonaws.com.
Service detected: HTTP
Testing for LUCKY13 vulnerability
LUCKY13 (CVE-2013-0169), experimental potentially VULNERABLE, uses cipher block chaining (CBC) ciphers with TLS. Check patches
```

4. BEAST Vulnerability

Medium

CVSS Score: 6.8

CVSS Vector: 3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N

CVE ID: CVE-2011-3389

Description:

BEAST (Browser Exploit Against SSL/TLS) is a cryptographic attack targeting the implementation of TLS 1.0 and SSL 3.0 when using block ciphers in CBC (Cipher Block Chaining) mode.

An attacker exploiting BEAST can decrypt and extract secure HTTPS cookies or data by performing a man-in-the-middle (MITM) attack and injecting malicious JavaScript to observe encrypted traffic patterns.

The attack exploits how TLS 1.0 handles initialization vectors (IVs) in CBC-mode ciphers. Although TLS 1.1 and 1.2 fixed this design flaw, many servers and browsers were still using TLS 1.0 when BEAST was discovered.

Solution:

- Restrict Disable SSL 3.0 and TLS 1.0 on servers.
- Use TLS 1.2 or TLS 1.3 with AEAD ciphers like AES-GCM or ChaCha20.
- Use strong forward-secret cipher suites:
 - TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
 - TLS_AES_128_GCM_SHA256` (TLS 1.3)

Impact:

- Confidentiality: High — Sensitive information such as session tokens or cookies can be decrypted.
- Integrity: None
- Availability: None
- Could lead to session hijacking or unauthorized access.

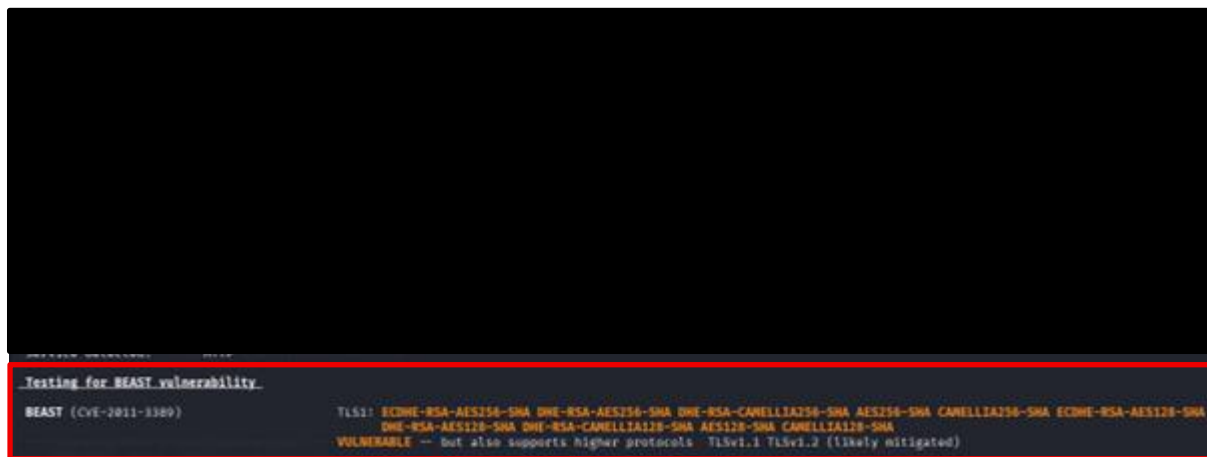
Remediation:

- Immediate Upgrade all servers to support and enforce TLS 1.2+.
- Disable SSL 3.0 and TLS 1.0 in all server configurations.
- Remove support for all weak CBC-mode cipher suites.
- Ensure modern browsers are used with up-to-date TLS stacks.

Reference:

- <https://nvd.nist.gov/vuln/detail/CVE-2011-3389>
- <https://vnhacker.blogspot.com/2011/09/beast.html>

Attached POC:



```
Testing for BEAST vulnerability...
BEAST (CVE-2011-3389)      TLS1: ECDHE-RSA-AES128-SHA DHE-RSA-AES128-SHA DHE-RSA-CAMELLIA128-SHA AES128-SHA CAMELLIA128-SHA ECDHE-RSA-AES128-SHA
DHE-RSA-AES128-SHA DHE-RSA-CAMELLIA128-SHA AES128-SHA CAMELLIA128-SHA
VULNERABLE -- but also supports higher protocols: TLSv1.1 TLSv1.2 (likely mitigated)
```


5. TLS Version 1.1 Deprecated Protocol

Medium

CVSS Score: 6.5

CVSS Vector: 3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

Description:

The remote service accepts connections using TLS 1.1, a deprecated cryptographic protocol. TLS 1.1 lacks support for modern, recommended cipher suites that provide strong security guarantees, such as authenticated encryption modes like GCM (Galois/Counter Mode). Moreover, TLS 1.1 does not support cipher suites that encrypt data after the Message Authentication Code (MAC) computation, which is considered a modern and more secure encryption approach. This means that connections using TLS 1.1 are more susceptible to cryptographic vulnerabilities like cipher block chaining (CBC) attacks and padding oracle attacks. Since TLS 1.1 is no longer considered secure, its use should be deprecated in favor of more secure versions such as TLS 1.2 or TLS 1.3, both of which provide support for stronger ciphers and better protection against attacks.

Solution:

- Disable TLS 1.1 in the server configuration and ensure that only TLS 1.2 and TLS 1.3 are enabled.
- Update and Patch: Ensure that your server software and cryptographic libraries are up to date to support TLS 1.2 and TLS 1.3.
- Test After Implementation: After updating your configuration, use SSL/TLS testing tools to ensure that the server only supports secure protocols and cipher suites.

Impact:

- Cryptographic Weaknesses: TLS 1.1 lacks support for the most current and secure cryptographic ciphers, making it vulnerable to attacks that newer versions mitigate.
- Regulatory Compliance: Many security standards and regulations (e.g., PCI DSS, HIPAA) require the use of TLS 1.2 or TLS 1.3 for secure communication, meaning TLS 1.1 may result in non-compliance.
- Data Integrity and Confidentiality: Using TLS 1.1 increases the risk of attacks such as man-in-the-middle (MitM), data interception, and tampering.

Remediation:

- Identify Supported TLS Versions:
- You can use tools like nmap to check which versions of TLS are supported by the server:
- `nmap --script ssl-enum-ciphers -p 443 <target_ip>`
- This will show all supported versions of TLS and SSL, including TLS 1.1.
- Disable TLS 1.1 in the Server Configuration:

- For Apache:
 - Edit the `ssl.conf` or `httpd.conf` file:
 - `SSLProtocol all -SSLv2 -SSLv3 -TLSv1 -TLSv1.1`
 - This disables TLSv1, TLSv1.1, SSLv2, and SSLv3, leaving only TLS 1.2 and TLS 1.3 enabled.
- For Nginx:
 - Edit the `nginx.conf` file:
 - `ssl_protocols TLSv1.2 TLSv1.3;`
 - This explicitly allows only TLS 1.2 and TLS 1.3.
- For Java-based servers (e.g., Tomcat):
 - Edit the `server.xml` configuration file to disable older protocols:
 - `<Connector protocol="org.apache.coyote.http11.Http11NioProtocol"`
 - `sslEnabledProtocols="TLSv1.2, TLSv1.3" />`
- **Restart the Server:**
 - After making the changes, restart the service (e.g., Apache, Nginx, or Tomcat) to apply the configuration changes.
- **Test the Configuration:**
 - Verify that TLS 1.1 has been disabled and that the server supports only the desired versions (TLS 1.2 and TLS 1.3).
 - Use tools like SSL Labs' [SSL Test] (<https://www.ssllabs.com/ssltest/>) to check the server's supported protocols.

Reference:

- <https://csrc.nist.gov/publications/detail/sp/800-52/rev-2/final>
- https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html

Attached POC:

```
(kali@kali)~$  
  
TLSv1.0:  
ciphers:  
  TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A  
  TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - A  
  TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (dh 1024) - A  
  TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A  
  
TLSv1.1:  
ciphers:  
  TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - A  
  TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - A  
  TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (dh 1024) - A  
  TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
```

6. HSTS Missing from HTTPS Server

Medium

CVSS Score: 6.5

CVSS Vector: 3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Description:

The server supports HTTPS but does not implement HTTP Strict Transport Security (HSTS), a response header ('Strict-Transport-Security') defined in RFC 6797.

Without this header, an attacker performing a man-in-the-middle (MITM) attack can downgrade HTTPS to HTTP, exposing users to: SSL stripping, Session hijacking, Credential theft

Solution:

- Restrict Implement HSTS by sending the following header over HTTPS responses:
- Strict-Transport-Security: max-age=31536000; include subdomain preload
- Add header Strict-Transport-Security "max-age=31536000; include Subdomain preload" always;

Impact:

- Confidentiality: Medium — Data may be transmitted over insecure HTTP.
- Integrity: Medium — The attacker may modify or inject data into downgraded sessions.
- Availability: None
- May result in cookie/session hijacking, phishing via domain impersonation, and non-compliance with security best practices like OWASP and PCI-DSS.

Remediation:

- Configure your web server to send the HSTS header on all HTTPS responses.
- Ensure that all HTTP traffic is redirected to HTTPS.
- Enable include subdomain if all subdomains support HTTPS
- Test using security tools or `curl -I https://example.com`

Reference:

- [RFC 6797 - HTTP Strict Transport Security \(HSTS\)](#)
- [HTTP Strict Transport Security - OWASP Cheat Sheet Series](#)

Attached POC:

```
HTTP/1.1 200 OK
Server: nginx/1.10.3 (Ubuntu)
Date: Tue, 29 Jul 2025 05:31:27 GMT
Content-Type: text/html
Content-Length: 851
Last-Modified: Mon, 07 Jul 2025 16:02:46 GMT
Connection: keep-alive
ETag: "686befa6-353"
Accept-Ranges: bytes
```

Attacks and Exploits Performed

The following list of potential attacks and exploits has been tested, and the corresponding results are provided.

Sr. No	Attack or Exploit Details	Result
1.	Microsoft Message Queuing RCE (CVE-2023-21554, QueueJumper)	Not Vulnerable
2.	NFS Shares World Readable Vulnerability	Not Vulnerable
3.	OpenSSL Heartbeat Information Disclosure (Heartbleed)	Not Vulnerable
4.	Remote Code Execution via Microsoft Server Service Vulnerability	Not Vulnerable
5.	SSL RC4 Cipher Suites Supported (Bar Mitzvah)	Not Vulnerable
6.	OpenSSL 'ChangeCipherSpec' MiTM Vulnerability	Not Vulnerable
7.	OpenSSH Vulnerable version in use	Not Vulnerable
8.	Microsoft Windows SMB Shares Unprivileged Access	Not Vulnerable
9.	Remote Desktop Protocol Server Man-in-the-Middle Weakness	Not Vulnerable
10.	Terminal Services Does Not Enforce Network Level Authentication (NLA) Only	Not Vulnerable
11.	DNS Server Cache Snooping Remote Information Disclosure	Not Vulnerable
12.	Apache HTTP Server Multiple Vulnerabilities	Not Vulnerable
13.	POODLE attack	Not Vulnerable
14.	Logjam	Vulnerable
15.	DNS Detection (Remote Network)	Not Vulnerable
16.	Unencrypted Telnet Server	Not Vulnerable
17.	MITM Plaintext Data Injection	Not Vulnerable
18.	SNMP Request Cisco Router Information Disclosure	Not Vulnerable
19.	SNMP Agent Default Community Name (public)	Not Vulnerable
20.	Microsoft SQL Server 2022 – Banner & Vulnerability Exposure	Not Vulnerable
21.	MS17_010 (Eternal Blue)	Not Vulnerable
22.	Microsoft Windows IIS Default Index Page	Not Vulnerable
23.	Heartbleed (CVE-2014-0160)	Not Vulnerable
24.	Oracle Database Server Multiple Vulnerabilities	Not Vulnerable

25.	Unrestricted RPC over HTTP Exposure with Banner Disclosure	Not Vulnerable
26.	LUCKY13 (CVE-2013-0169)	Vulnerable
27.	DROWN Attack (CVE-2016-0800, CVE-2016-0703)	Not Vulnerable
28.	BEAST (CVE-2011-3389)	Vulnerable
29.	Outdated Nginx Version with Known Vulnerabilities	Vulnerable
30.	TCP/IP Sequence Prediction Blind Reset Spoofing DoS	Not Vulnerable
31.	Buffer Overflow	Not Vulnerable
32.	SWEET32	Not Vulnerable
33.	DNS Server Dynamic Update Record Injection	Not Vulnerable
34.	SSH Weak Key Exchange Algorithms Enabled	Not Vulnerable
35.	PHP Multiple Vulnerabilities	Not Vulnerable
36.	Microsoft UPnP Local Privilege Elevation Vulnerability	Not Vulnerable
37.	Samba Unsupported Version Detection	Not Vulnerable
38.	Samba Badlock Vulnerability	Not Vulnerable
39.	NetBIOS Remote Code Execution	Not Vulnerable
40.	SSL Self Signed Certificate	Not Vulnerable
41.	SSH Server CBC Mode Ciphers Enabled	Not Vulnerable
42.	SSH Weak MAC Algorithms Enabled	Not Vulnerable
43.	SSL Certificate Cannot Be Trusted	Not Vulnerable
44.	TLS Version 1.0 Protocol Detection	Not Vulnerable
45.	TLS Version 1.1 Protocol Detection	Not Vulnerable
46.	TLS Version 1.1 Deprecated Protocol	Vulnerable
47.	ICMP Timestamp Request Remote Date Disclosure	Not Vulnerable
48.	DNS Server Zone Transfer Information Disclosure	Not Vulnerable
49.	HSTS Missing from HTTPS Server	Vulnerable
50.	Weblogic Unauthorized bypass RCE	Not Vulnerable
51.	Microsoft IIS WebDAV Write Access Code Execution	Not Vulnerable
52.	MS09-020 IIS6 WebDAV Unicode Authentication Bypass	Not Vulnerable
53.	ArubaOS-Switch Denial of Service (DoS) Vulnerability	Not Vulnerable

54.	Tomcat - Remote Code Execution via JSP Upload Bypass	Not Vulnerable
55.	Apache Tomcat AJP File Read	Not Vulnerable
56.	SSH Weak Algorithms Supported	Not Vulnerable
57.	SSL Version 2 and 3 Protocol Detection	Not Vulnerable
58.	SMB DOUBLEPULSAR Remote Code Execution	Not Vulnerable
59.	SMB Signing Not Required	Not Vulnerable
60.	Linux Multiple statd Packages Remote Format String Vulnerability	Not Vulnerable
61.	IPMI v2.0 Password Hash Disclosure	Not Vulnerable
62.	Web Server HTTP Header Information Disclosure	Not Vulnerable
63.	Web Server Directory Traversal	Not Vulnerable
64.	Oracle WebLogic Unsupported Version Detection	Not Vulnerable
65.	Spring4Shell (CVE-2022-22965)	Not Vulnerable
66.	HTTP TRACE / TRACK Methods Allowed	Not Vulnerable
67.	IP Forwarding Enabled	Not Vulnerable
68.	Gunicorn Misconfiguration	Not Vulnerable

Appendix A – Vulnerability Severity Rating

Vision Networks rates the impact of individual vulnerabilities as **Critical**, **High**, **Medium**, **Low** & **Info** severity ratings. The scale considers the potential risk of a flaw based on a technical analysis of the exact flaws and its type.

Level	Description
Critical	Vulnerabilities identified at the Critical Severity level should be investigated immediately. Vulnerabilities at this level assume exploitation of the flaw could lead to full system or data compromise. Examples of critical severity flaws are Command/Code Injection and SQL Injection. Typically, these flaws are rated with CVSS 3.1 between 9.0-10.0.
High	Based on the existing controls and information processed, there is a certainty that sensitive information will be susceptible to disclosure, tampering and/or disruption to critical infrastructure. High level vulnerabilities are categorized as the most dangerous, which put a site at maximum risk for hacking and data theft.
Medium	Risk exposure that does not directly compromise the confidentiality, integrity, and/or availability of the areas tested. However, there is a likelihood of intrusion given the current controls, and recommended controls should be implemented to further minimize the risks and constant monitoring should be performed to respond to malicious activities. Medium level vulnerabilities are generally caused by server miss-configuration and site-coding flaws, which facilitate server disruption and directory intrusion
Low	Risk exposure that impacts insignificant business processes/information, or the likelihood of occurrence is negligible. The recommended measures may be implemented to enhance the security posture of the overall infrastructure/processes. Low Level Vulnerabilities are generally caused by server miss-configuration, or directory path disclosures, etc.
Info	Info vulnerabilities includes visible information about the network related to the host, such as traceroute information, Internet Service Provider (ISP), or a list of reachable hosts. Intruders may be able to retrieve sensitive information related to the host, such as open UDP and TCP services lists, and detection of firewalls.